AIガバナンス実務資料

個人情報×生成AI 実務ガイド

個人情報を扱う組織のための、判定フローと要配慮個人情報を扱う場合の技術構成 — 2026年10月時点の公式一次情報を根拠に組み立て直す実務資料（社内検証値は[†]で明示）

最終確認 2026-10-12 | 一次情報ベース・出典32件 | 対象：個人情報を扱う組織（民間向けの条文を中心に整理） | 最新版はこちら ↗

この資料でわかること

- 個人情報保護法が課す「2つの独立した義務」の違いと、それぞれの解決手段
- AIに入れてよい情報のレベルを、3つの質問だけで判定する方法
- 「ISMAP登録済み」という言葉が実際に意味すること・意味しないこと
- 越境移転規制（法28条）が生成AI利用に与える具体的な影響
- 要配慮個人情報を実名で扱うための、現実的な技術構成とコストの根拠

対象読者：個人情報・要配慮個人情報を扱いながら生成AIの活用を検討する、福祉施設・自治体・NPO・中小企業等の意思決定者および情報システム担当者。特定のベンダーやサービスの宣伝を目的としたものではありません。本文中の [n] は巻末「出典一覧」の番号に対応します。

CONTENTS

目次

00 **はじめに** p.3
なぜこの整理が必要か

01 **大原則：個人情報保護法の「2つの壁」** p.4
安全管理措置と、適法な取得・利用は独立している

02 **判定フロー：3つの質問** p.5
個人特定情報／要配慮個人情報／処理体制の3段階判定

03 **越境移転規制（法28条）** p.7
「日本国内処理」が重視される法的背景

03+ **補足：適用範囲・生成AIの注意喚起・令和8年改正** p.8
民間と行政機関等の違い、法改正、医療情報ガイドライン

04 **ISMAP登録の構造と落とし穴** p.9
「登録済み」が自動的に意味しないもの

05 **実名データの3段階（Tier A / B / C）** p.10
用途別に必要な技術要件を切り分ける

06 **よくある間違いと正しい対応** p.11
NG例・OK例で確認する、現場で起きがちなずれ

07 **Tier Cの技術構成とその根拠** p.13
要配慮個人情報のための現実的なアーキテクチャ

08 **技術を固めても残る法務対応** p.15
積み上げれば完了する軸と、終わりのない軸の違い

09 **まとめ：今日からできること** p.16
できること・まだできないこと・準備すべきこと

10 **入力してよい環境のチェックリスト** p.17
ここまで整えば入力してよい前提環境と整理する

– **出典一覧** p.18
本文中の番号に対応する公式情報源、32件

各社の規約・料金・対応リージョンは頻繁に更新されます。意思決定の直前には、出典一覧のリンクから必ず最新情報を確認してください。

「ISMAPを満たしているから安全」——それ、半分しか合っていません

個人情報を扱う組織が生成AIの導入を検討する際、「ISMAPを満たしているので個人情報を安全に取り扱える」という説明に出会うことがあります。では実際には、どのレベルの情報まで入力してよいのでしょうか。

> この質問の背景には、よくある誤解があります。「ISMAP登録済み」「学習に使われない」といった言葉は、**安全に“守る”仕組み**があるかどうかの話でしかありません。そもそも**その情報を扱ってよいか**は、まったく別の判断軸です。

この資料の狙い

この資料は、上記のような現場の疑問に対して、2026年10月12日時点で確認できる公式一次情報を根拠に（社内検証値は[†]で明示）、次の2つを整理し直したものです。

1. **判定フロー** — 手元のデータをAIに入れてよいかを、3つの質問で判定する方法（第2章）
2. **技術構成** — 要配慮個人情報を実名で扱わざるを得ない場合に、現実的に組める技術構成とその根拠（第7章）

読み方

本文中の **[n]** は、巻末「出典一覧」（p.18）の番号に対応します。日本語OCRの精度比較のみ、社内の非公開実機検証に基づく知見のため、**[†]** で示し公開リンクなしと明記しています。専門的な法律用語には、初出時に簡単な説明を添えています。

なお本資料は、特定の福祉施設・自治体・団体名や個別の相談内容には触れていません。個人情報を扱いながら生成AIの活用を検討する組織全般に共通する論点として整理しています。

「安全に守る」義務と「そもそも使ってよいか」の義務は、独立している

個人情報保護法は、大きく分けて2つの義務を組織に課しています。この2つは監督する条文も、満たす手段もまったく別物であり、**片方を満たしても、もう片方の違反は消えません。**

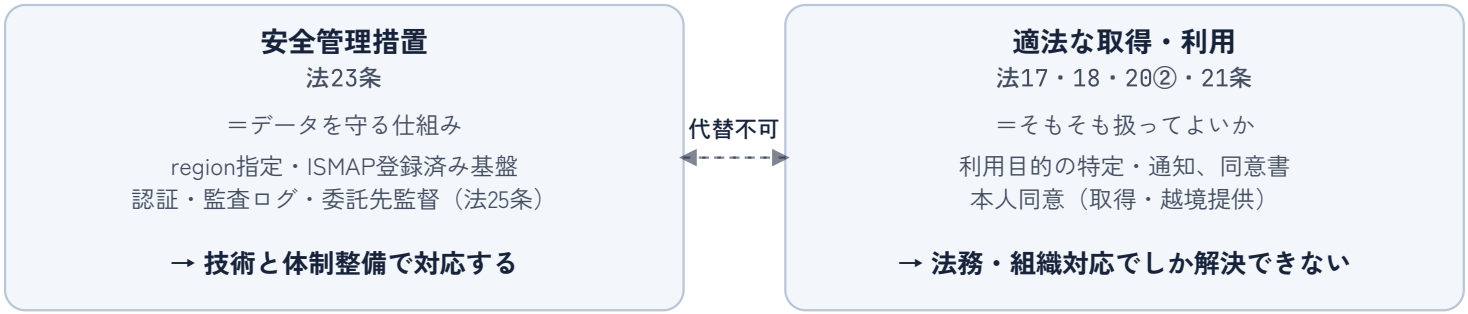


図1. 個人情報保護法が課す2つの独立した義務。片方（技術）を満たしても他方（法務）の代わりにはならない。

関係する条文の早見表

条文	内容	区分
17条	利用目的の特定	法務
18条	利用目的による制限（目的外利用の禁止）	法務
20条2項	要配慮個人情報の取得には原則本人同意が必要	法務
21条	取得に際しての利用目的の通知・公表	法務
23条	安全管理措置（データを守る技術・体制）	技術
25条	委託先の監督	技術+法務
27条	第三者提供の制限（原則。委託は5項1号で第三者に非該当）	法務
28条	外国にある第三者への提供の制限（越境移転規制）	技術+法務

条文番号は2026年10月12日時点で施行中の法に基づく[3]。令和8年改正は未施行[16]。

3つの質問で、入れていいレベルが決まる

「結局、どのレベルから個人情報を入れてよいのか」という疑問に、3段階の質問で答えます。**「はい」を辿るほど要件は厳しくなり、要配慮個人情報は必ず最後の質問まで確認する必要があります。**

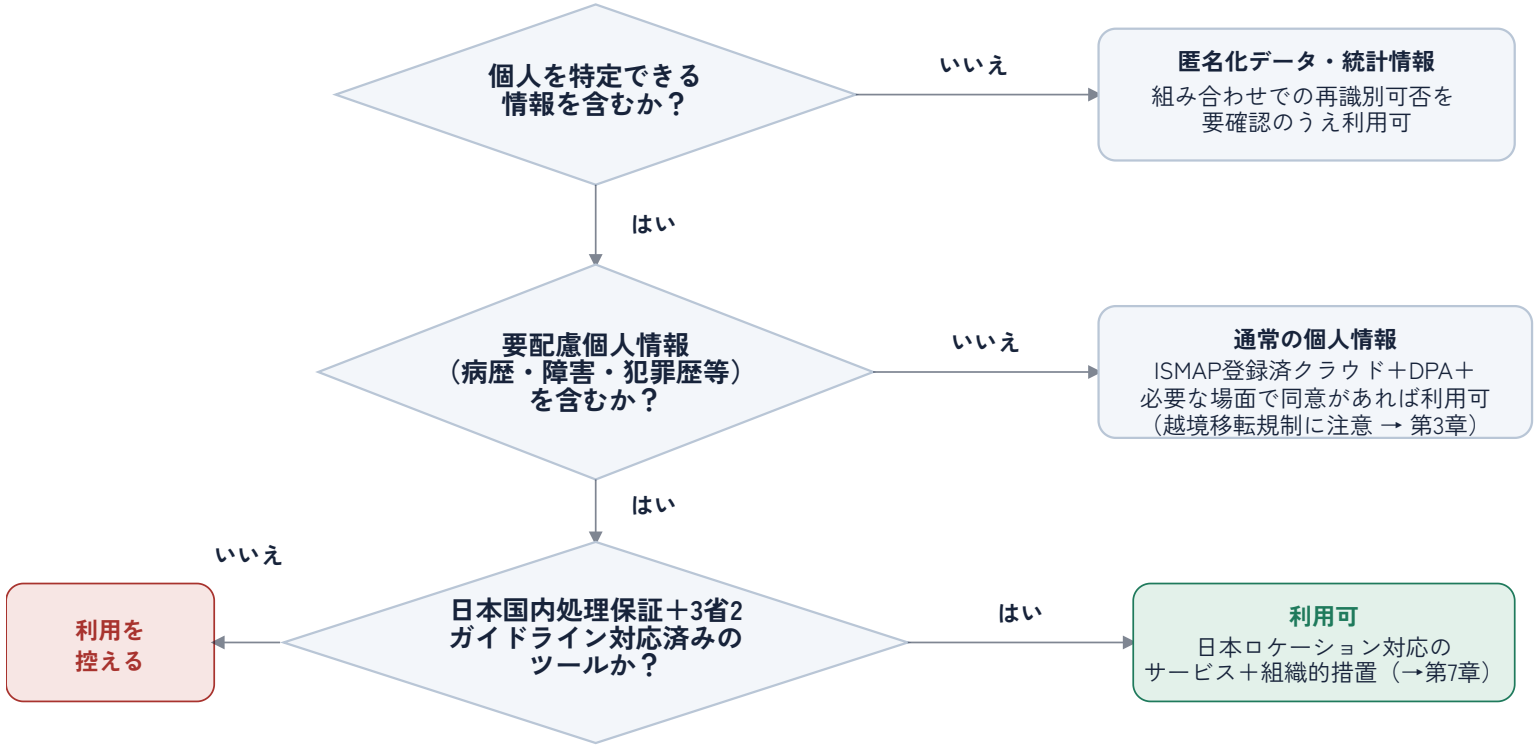


図2. 個人情報のレベル別判定フロー。DPA＝データ処理契約（第8章で詳述）。3省2ガイドライン＝厚生労働省・総務省・経済産業省が定める医療情報の安全管理ガイドライン群（第3章補足参照）。第2・第3問の要件は法令の最低要件ではなく、本資料が安全側に整理した推奨水準で、実際には法17〜28条の個別の充足が必要。

具体例早見表

実務でよく出てくる入力内容を、上記フローに沿って分類すると次のようになります。

入力しようとしている内容の例	分類	目安
一般的な案内文・チラシのひな形（個人名なし）	匿名化情報	問題なし
研修資料・マニュアルの下書き	匿名化情報	問題なし
施設名・職員の氏名	通常の個人情報	条件付きで可
利用者の氏名・住所・連絡先のみ	通常の個人情報	条件付きで可
利用者の病歴・障害の状況・障害福祉サービスの利用事実[3]	要配慮個人情報	非推奨
逮捕歴・犯罪の経歴	要配慮個人情報	非推奨
ケース記録全般（病歴・生活歴等を含む）	要配慮個人情報を含む可能性大	非推奨（個別確認）

「匿名化済みだから安全」の落とし穴

氏名等の直接的な識別子を除いても、**年代＋地域＋利用施設のように複数の属性を組み合わせると、本人が再識別できてしまう場合があります。**「個人を特定できる情報を含まないか」の判定は、単一の項目だけでなく組み合わせの観点でも行う必要があります。判断に迷う場合は、常に「入れない」を選ぶことが原則です。

生活保護受給歴の扱いについての注記

「生活保護の受給歴」そのものは、個人情報保護法が列挙する要配慮個人情報の定義に直接該当するとは限りません[3]。しかし、ケース記録には病歴・障害等の要配慮個人情報が併記されることが多く、実務上は要配慮情報に準じた慎重な取り扱いが妥当です。個別の該当性判断は専門家にご確認ください。

「日本国内処理」が重視される理由 — 個人情報保護法28条

安全管理措置（法23条）やISMAP登録の有無とは別に、もう一つ重要な論点があります。**外国にある第三者への提供の制限（法28条）**です。この規定は、令和3年改正法（令和3年法律第37号）を経て、旧24条から現在の28条になっています[1]。

法28条が問題になるのは、個人データの提供先が**「外国にある第三者」**に当たる場合です。判断の軸はデータセンターの所在地ではなく、提供先の事業者の所在・法人格と実態です。外国法人でも、日本国内で個人情報データベース等を事業の用に供していると認められる場合は該当しません（個別判断）[1][15]。当たる場合、次のいずれかに該当しない限り、**あらかじめ本人の同意を得ること**が必要で、委託先への提供も対象です[15]。

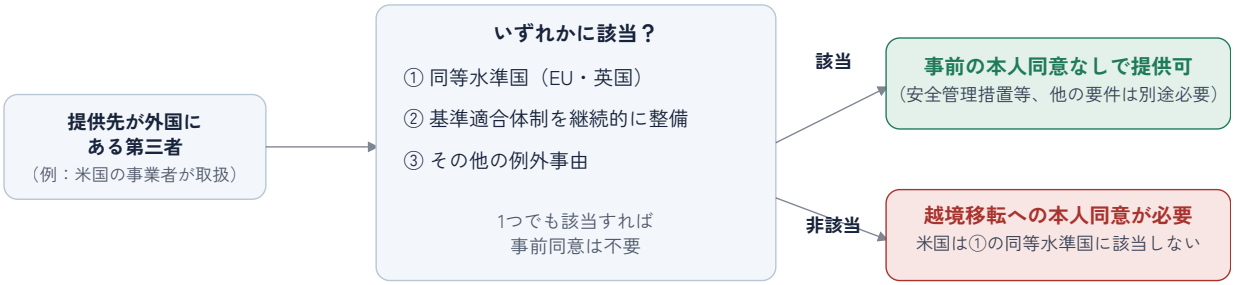


図3. 個人情報保護法28条の判定構造[1]。ISMAP登録や安全管理措置（法23条）の充足は、この論点をクリアする根拠にはならない。

個人情報保護委員会は、EU（欧州連合）と英国を「個人の権利利益を保護する上で我が国と同等の水準にあると認められる国」として指定しています[1][2]。米国は対象外です。生成AIサービスには処理地を米国・グローバル等から選ぶ設計のものが多く、提供先が外国にある第三者に当たり、かつ上の例外（基準適合体制など）にも該当しないなら、外国名等の情報提供を伴う本人同意が必要です。同意は書面に限られずメールやWeb上の確認欄でも足りますが、判断能力が十分でない方（未成年者・成年被後見人等）は親権者や法定代理人からの同意が必要です[3]。

他方、クラウド事業者が契約上個人データを取り扱わず、アクセス制御も適切な場合は「提供」に当たりません（Q7-53・Q12-3・Q12-4）。この場合も、外国の制度等の把握を含む安全管理措置と、サーバ所在国等の本人への公表は必要です（Q10-25）[15]。生成AIが入力を応答の出力のためだけに処理する場合の法28条上の扱いは、2026年10月12日時点でPPCが個別に示していないため、国外処理を伴うときは同意取得を前提に置き、契約条項と運用の実態を専門家に確認してください。

この資料の前提：適用範囲・生成AI・令和8年改正

① 適用範囲：民間事業者と行政機関等で条文が違う

本資料の条文番号（法17〜28条等）は、民間の個人情報取扱事業者向けの第4章の規律です。国の機関・自治体等の「行政機関等」は第5章で、安全管理は法66条、利用・提供の制限は法69条、外国にある第三者への提供の制限は法71条（目的外提供の場合）と構造が異なります[27][29]。民間の福祉施設・NPO・中小企業は原則第4章、独立行政法人等・自治体は設立形態により第5章のため、所管部門等に確認してください。自治体は条例と、デジタル庁の生成AIガイドライン第2.0版[26]も参照してください。

② 生成AIへのPPC注意喚起（令和5年6月）[23]

- 個人情報を含むプロンプトを入力するときは、特定した利用目的の達成に必要な範囲内か確認する。
- 本人の同意なく個人データを入力し、それが応答出力以外の目的で取り扱われる場合、法違反となる可能性がある。事業者が機械学習に利用しないこと等を確認する。

行政機関等にも同旨です。処理地とは別に、「入力が学習等に使われない」ことの契約・設定上の確認が必要です。

③ 令和8年改正法（2026年7月17日公布）は主要部分が未施行[16]

原則として公布から2年以内に政令で定める日に施行され、一部は公布日または6か月後に施行されます（附則第1条）。主要部分は2026年10月12日時点で未施行のため、現行法に基づきます。概要資料は、統計作成等の同意規制の見直し、委託先への規律、16歳未満の個人情報、課徴金制度等を挙げます。法28条1項も用語整理の改正対象で、27条の見直しと併せ影響しうるため、政令公表後に確認します。

④ 福祉・介護分野と医療情報ガイドラインの位置づけ

PPCの特定分野GL一覧に福祉分野固有のものはなく、介護事業者等向けに「医療・介護関係事業者における個人情報の適切な取扱いのためのガイダンス」（令和8年4月改正）があります[28]。

「3省2ガイドライン」は、厚労省「医療情報システムの安全管理に関するガイドライン」第7.0版（令和8年6月）[24]と、経産省・総務省「医療情報を取り扱う情報システム・サービスの提供事業者における安全管理ガイドライン」第2.0版（令和7年3月）[25]です。第2.0版は、医療機関等との契約等に基づく事業者などにPマークまたはISMS認証（政府のクラウド認証等で代替可。取得のみでは水準を満たさない）を求め、医療従事者の指示に基づく情報を扱う介護事業者のシステムも対象です（福祉施設は案件ごとに確認し、参考水準）[25]。

「基盤の登録」は「上位サービス」に自動継承されない

ISMAP（政府情報システムのためのセキュリティ評価制度）は、国家サイバー統括室・デジタル庁・総務省・経済産業省が所管し、IPA（情報処理推進機構）が運用支援機関として実務を担う、令和2年1月30日決定の基本的枠組みに基づく制度です[31]。評価済のクラウドサービスは、ISMAPクラウドサービスリストに登録番号とともに掲載されます[5]。

ISMAPは政府のクラウド調達の制度で、民間事業者に登録サービスの利用を求める規定は、法令本文・通則編・外国提供編・Q&Aでは確認できませんでした[27][3][15]。安全管理措置（法23条）の検討では水準の目安の一つです。政府機関等が生成AIを使う場合は、ISMAPとは別のリスク対応が必要です[6]。

ここで見落とされがちなのが、**「登録済みの基盤の上に構築されたサービスが、自動的に同じ扱いになるとは限らない」**という原則です。ISMAP公式FAQは次のように明記しています。

> *「提供しているSaaSの基盤部分としてISMAPクラウドサービスリストに登録されているIaaS、PaaSを用いていたとしても、…ISMAPに登録されているサービスと同等とみなすことはできません。」[4]*



図4. Google関連は3つの独立した登録番号に分かれる一方、AWSはBedrockを含む単一登録[5][7][8]。個々のモデルは、生成AI開発基盤を言明対象範囲に含めて登録した場合に限り別途登録不要で、生成AI特有のリスクは事業者側で別途措置が必要という点がISMAP運営主体の公式見解[6]。

実際、Gemini Enterprise（C26-0114-2）はGoogle Cloud（C21-0004-2）のストレージ等を基盤に利用しているにもかかわらず、2026年4月28日に別途本登録が行われました[5][7]（SaaSとして提供する生成AIサービスは原則登録が必要とされています[6]）。「基盤がISMAPだから上位のSaaS機能も自動的にISMAP」という推論は成立しません。なお、言明対象範囲の公開資料にはエディション別の記載がなく、Business版が対象に含まれるかは公開情報から確認できません（要確認）[5]。

Tier A / B / C — 右に行くほど要件が跳ね上がる

実名データの技術要件は、機微度によって3段階に分かれます（法令の最低要件ではなく、本資料の推奨水準）。

TIER	代表的な用途	必要な技術要件
A 匿名化	個人が特定されない一般的な文章生成・要約・案内文作成	特別な要件なし。一般的なクラウドAIで可
B 通常の個人情報（実名）	施設名・担当者名等を含む議事録・案内文	ISMAP登録済みクラウド（目安）＋DPA締結＋法が求める場面での本人同意。日本リージョン限定は必須ではないが推奨（第3章）
C 要配慮個人情報（実名）	ケースワーク記録の要約、相談面談音声の議事録、書類のAI OCR化	Bの要件に加え、データの保存＋AI処理が日本国内に完全に閉じること、APIキーレス認証、3省2ガイドライン相当の組織的措置

Tier Bで利用可能な選択肢／避けるべき選択肢

- **Gemini in Workspace** — Workspace自体がISMAP登録済みで、Geminiアプリ・Gemini in Workspaceも対象[5][14]。保存地域に日本はない[19]が、Tier Bでは許容
- **Gemini Enterprise（Standard/Plus）** — 別契約。日本で保存・ML処理を固定可（allowlist制）。日本非対応の機能を管理者が有効化するとグローバル送信[17]。Business版は不可[18]
- **Vertex AI（現Gemini Enterprise Agent Platform）のAPI** — ISMAP言明書上は「Vertex AI Platform」として対象[5]。Tier Bなら全リージョン可

❌ **Google AI Studioの素のAPIキー**はNG。ISMAPリスト未登録。無料枠は入力が製品改善に使われ、有料でも一時保存・キャッシュが国を問わず行われうる[13]

補足（Gemini Enterpriseの無料トライアル）：30日間の無料トライアルがあり（Business版はIT設定不要）[12]、「トグルがオン」＝「正式に契約済み」とは限りません。契約状況を確認してください。

同じ「Gemini in Workspace」でも、使い方で明暗が分かれる

ここまでの判定フローとTier分類を理解していても、現場では「良かれと思って」誤った使い方をしてしまうことがあります。最も多いのが、次のケースです。

❌ NG例：相談記録をそのまま要約させている

職員が、利用者の氏名・病歴・生活状況を含む相談記録を、法人契約のGemini in Workspaceに貼り付けて「要約して」と依頼している。ISMAP登録済みだから安全だと考えている。

実態：これは `Tier C` のデータを `Tier B` の環境で処理している状態。ISMAP登録済みで安全管理面の目安は満たしていても、①入力データが応答出力以外（学習等）に使われないか未確認（PPC注意喚起[23]）、②提供先が外国にある第三者に当たる場合の同意（法28条）と、利用目的の範囲（法17・18条）[3]の確認が残ったままです。

✅ OK例：用途に応じて仕分けている

同じ相談記録でも、案内文の下書き程度なら氏名等を「A様」に置き換えてから、同じGemini in Workspaceで作成。病歴・生活歴を含む要約作業は、正式なTier C構成（第7章）が整うまで人手で行うと決めている。

ポイント：ツールを変えなくても、「何を入れるか」を仕分けるだけでリスクは大きく下がります。困ったら、まず匿名化してからが原則です。

なぜ組織は気づきにくいのか

「ISMAP登録済み」「大手ベンダーの法人契約」という言葉が、安心感を生みやすいためです。しかし第1章・第4章で見たとおり、ISMAP登録（安全管理措置）と、越境移転規制・同意取得（適法な取得・利用）は**独立した別の壁**です。片方が万全でも、もう片方はクリアできていない、という状態が最も見落とされやすいパターンです。

見分け方：3秒でできるセルフチェック

入力しようとしている文章に、①氏名・住所等の直接的な識別子、②病歴・障害・犯罪歴等の要配慮情報、③年代＋地域＋利用施設のような組み合わせ、のいずれかが残っていないか。1つでも該当するなら、それは `Tier C` 相当の可能性が高く、通常のGemini in Workspaceでの処理は避けるべきタイミングです（判定フローは第2章）。

見落としやすい、もう2つのケース

ケース2：個人のGoogleアカウント・個人契約のAIを業務で使う

NG：職員が自分のスマホの個人Googleアカウント、または個人契約のChatGPT・Geminiアプリで、隙間時間に相談記録の下書きを作っている。

問題：個人プランは設定により入力が学習対象になりうる上、監査ログもない。退職時のデータ持ち出しを止められず、そもそも法人としての委託契約（法25条）が存在しません。

OK：法人契約（Gemini in Workspace等）に一本化し、内規で個人アカウントの業務利用を明示的に禁止している。

ポイント：「便利だから個人アカウントで」を許容した瞬間、監査ログ・DPA・委託先監督のすべてが空白になります。

ケース3：Google AI StudioのAPIキーで自作した社内ツール

NG：情報システム担当者がGoogle AI Studioで発行した無料のAPIキーを使い、社内向けの文書要約ツールを自作。便利なので現場が要配慮個人情報を含む文書もどんどん投入している。

問題：このAPIキーはISMAPリスト未登録の別製品で、無料枠は入力が製品改善に使われうる仕様です[13]。「自分たちで作ったから安心」という思い込みが、実は最も無防備な経路になっている典型例です。

OK：同じ機能をVertex AI（Gemini Enterprise Agent Platform）のAPI経由で作り直す。ISMAP登録済みの環境の範囲内に収まります。

ポイント：「内製・自作だから安全」とは限りません。むしろ管理者の目が届きにくく、リスクが放置されやすい経路です。

この3つのケースはいずれも、**①扱っているデータの機微度**と、**②実際に使っているツールの体制**がずれていることが原因です。ずれに気づいたら、次章（Tier Cの技術構成）で扱う正式な移行を検討してください。

07 TIER Cの技術構成

要配慮個人情報を実名で扱う場合の、現実的な最適構成

2026年10月時点で、自社アプリにAI機能を組み込む場合に費用面で最も現実的なのは、Google Cloudインフラを維持しつつ、生成・要約・音声文字起こしをAWS Bedrockに任せるハイブリッド構成が標準です。ただし**AI OCRは例外**で、自前ホスティングへ切り出します（理由は次頁）。要約など限定的な文章生成は、軽量モデル（Sarashina2.2-3B-instruct、MIT[32]）をCloud RunのCPU・日本リージョンに置く選択肢もあります。性能はClaude級に劣りますが、入力は自前コンテナ内で処理されモデル事業者に渡りません。基盤はGoogle Cloudのままで、国外法の適用可能性等は別途確認します[24][†]。

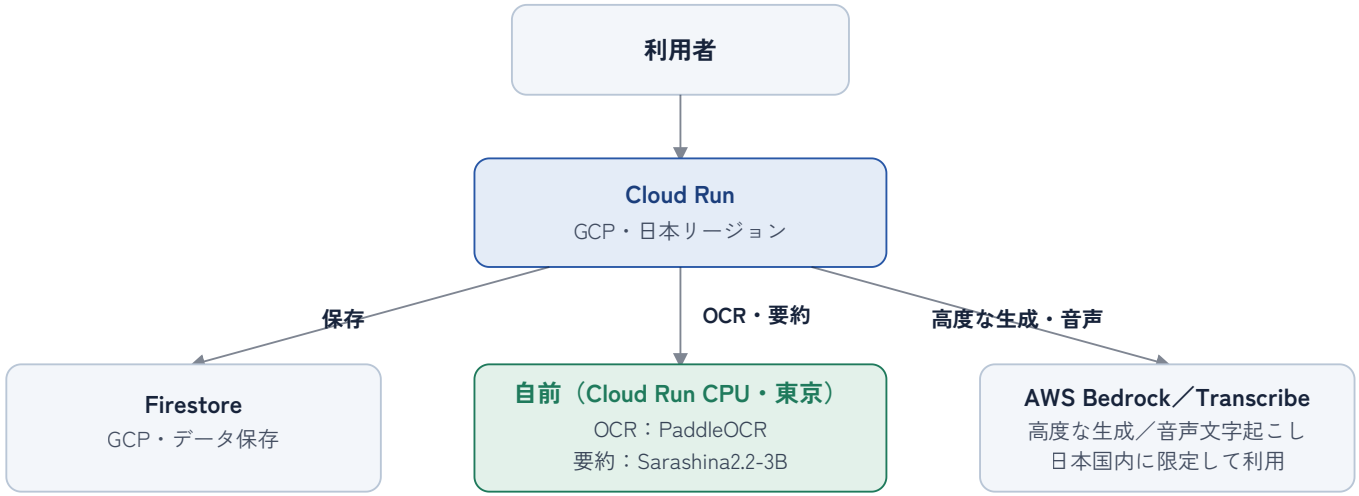


図5. データの保存・AI処理は常に日本国内に閉じる。OCRと限定的な要約は自前ホスティングへ、高度な生成と音声はAWS Bedrockへ（日本国内限定の推論プロファイルを指定[21][22]）。クラウド間はキーレス認証。

技術を固めても残る法務対応

- 利用者への同意取得・プライバシーポリシー改定
- クラウド事業者とのDPA（データ処理契約）締結
- 委託先とのNDA（秘密保持契約）・業務委託契約
- 3省2ガイドライン相当の組織的措置

この構成が変わりうる条件

各社の料金・対応リージョンは頻繁に変わります。Bedrockは使うモデルごとに日本プロファイル（jp.）と宛先リージョンをGetInferenceProfile で確認してください[22][30]。契約更新時にも出典一覧から再確認を。

コストと精度、両方の一次情報が同じ結論を指す

コスト構造

Gemini 3.5 Flashを日本リージョン（asia-northeast1）のAPIで使う場合、標準従量課金（Standard PayGo）は非対応です（対応はglobal・us・eu）[9]。利用できるのは単一ゾーンのProvisioned Throughputのみで、購入には「Google Cloudアカウント担当者への問い合わせ」が必須の個別契約になります[10]。公式料金ページでは、非グローバルのエンドポイントの単価は1か月コミットでGSUあたり約$4.07/時（月730時間換算で約 **$2,970**）と示され、必要なGSU数はモデルと処理量で決まります[11]。最新のGemini 3.8 Flashは日本リージョンでは提供されていません[9]。小規模な組織には現実的ではありません。対して、AWS Bedrockは固定費なしのオンデマンド利用で、日本国内クロスリージョン推論（jp.）は東京・大阪のみを宛先とし、Claude Sonnet 4.5・Haiku 4.5・Haiku 5.5・Opus 5.5、Nova 2 Liteなどが対応します（Sonnet 5.5はモデルカードに日本プロファイルの記載なし）[21][30]。APACやグローバルのプロファイルは国外を経由しうるため指定してはいけません[22]。ISMAPの対象範囲はBedrockを含みます（Bedrock Marketplaceを除く）[5][8]。

日本語OCR精度の実機比較

実際の日本語書類（旧字体異体字・類似漢字・事業所名の紛らわしいペア等）を使った実機検証では、AWS Bedrock（Claude／Nova系）は特定の漢字を再現性ある形で誤読することが確認されました。自前ホスティングのPaddleOCRは、Gemini系とほぼ同水準の精度を達成しています[†]。

モデル	正解率（96判定中）	備考
Gemini 2.5 Flash	100%	Google Cloud（Agent Platform）の提供終了日が2026年10月20日のため除外[20]
Gemini 3.5 Flash	99%（95/96）	
PaddleOCR（自前ホスティング）	98%（94/96）	Apache 2.0、東京リージョンCloud Run運用可
AWS Bedrock Claude Sonnet 4.5	約87.5%	
AWS Bedrock Claude Haiku 4.5	62.5〜75%	enum制約等の改善後の数値

評価軸：OCRテキストを既知のマスターリストにfuzzy matchで解決できるかという、実運用に即した基準[†]。いずれのモデルも「誤って別の実在レコードに確定する」危険な誤りは検証全体を通じて0件でした。要約用のSarashina2.2-3B-instructは、Q8_0量子化ならCPUで実用レベルでした。Q4_K_Mでは、情報が欠けた正式書式の書類で実在しない事業所名を捏造したため、避けてください[†]。

4つの軸——積み上げれば完了するもの、しないもの

アーキテクチャ（②）・NDA・DPA（③）・同意書（①）・ログ整備（④）を積み上げれば自動的に「合格」になる、というチェックリストではありません。要配慮個人情報を扱う体制は、性質の異なる次の4つの軸に分けて確認する必要があります。

#	軸	該当条文	何を見れば確認できるか
①	適法な取得・利用	17・18・20②・21条	**運営者の契約書・プライバシーポリシー実物のみ**。AI・コードからは確認不可能
②	安全管理措置	23条	アーキテクチャ調査で確認可能
③	委託先の監督	25条	NDA・DPA等の契約書の有無に加え、監督の実施記録（評価・監査履歴）まで必要
④	追跡可能性	23条（運用面）	ログ基盤の設定に加え、実際の保持運用の確認まで必要

①〜④を全部満たしても、「もう終わり」にはならない

②③④は「運営者⇔ベンダー」間の技術・契約対応で、委託先とのNDA・DPA締結（③）、アーキテクチャ整備（②）、ログ基盤の構築（④）という形で運営者とベンダーの間で整えられ、整備後も継続的な監督・見直しが必要です。しかし**①だけは「運営者⇔本人（サービス利用者）」間の同意**で、ベンダーとのNDA・DPA（③）をどれだけ強化しても①の代わりにはなりません。「同意書のひな形を用意した」ことと「既存の利用者全員から実際に同意を取得済みである」ことはまったく別の問題です。**つまり、利用者ごとに、法が求める場面（国外の第三者への提供、要配慮個人情報の取得など）で本人の同意を得る運用が必要**で、一度整えれば終わる話ではありません。同意は書面に限られませんが、取得の記録は残してください[3]。

マルチベンダー構成はコンプライアンス上むしろ改善しうる

「単一の生成AIベンダーに全タスクを寄せる」構成から、「最も機微データ密度が高い処理（例：生文書画像のOCR）だけを自前ホスティングに切り出し、それ以外を用途別に別ベンダーへ振り分ける」構成に変えると、生の機微データに触れる第三者事業者の数はむしろ減る方向に働きます。ベンダーを増やす＝リスク増、という直感は必ずしも正しくありません。ただし、既存の同意書・プライバシーポリシーが新しい委託先を含む処理を許容する記載になっているかは、都度レビューが必要です。

今日からできること、正直まだできないこと

✅ 今日からできる

個人が特定されない一般的な文章生成・要約・案内文は、今使っているツールのままで問題ありません。氏名・住所・生年月日等を仮名（A様、B様等）に置き換えれば、活用の幅はかなり広がります。「困ったら、まず匿名化してから」を職場のルールにするだけで効果があります。

❌ 正直、まだできない

利用者の実名と病歴・生活歴等を**そのまま**一般的なAIツールに入力すること。本人同意・委託先監督・越境移転対応・安全管理措置を個別に整えないまま行うのは避けてください。「今の契約・今のツールのまま」でこれらを満たしていると確認できるケースは、本資料が確認した範囲（2026年10月時点）では限られます。

組織として計画的に準備すべきこと

要配慮個人情報を実名で扱えるようにするには、個人のスマホ設定のように「その場で解決すること」ではなく、**システム構築と契約整理を伴う一定規模のプロジェクト**として進める必要があります。

- Tier C対応の技術基盤の構築（Gemini Enterprise Standard/Plusの日本ロケーション〔allowlist申請〕、またはAWS Bedrock日本国内推論等を用いたハイブリッド構成）
- 費用感の見積もりと予算確保（固定費が発生する構成もあるため事前の比較検討が必要）
- ISMAP登録範囲の個別確認（前章②）、クラウド事業者とのDPA締結（前章③）
- 3省2ガイドライン相当の組織的措置の整備
- 利用者への同意取得（前章①）・プライバシーポリシーの改定

「どこまで整えれば入力してよい環境と言えるか」は、第10章のチェックリストにまとめています。これらは技術・法務の両面にまたがる専門的な整理が必要で、片手間で進めるのは現実的ではありません。まずは「誰が意思決定者で、いつまでにどの範囲を実現したいか」を組織内で確認するところから始めることをおすすめします。

ここまで整えば、要配慮個人情報を実名で入れてよい前提環境と整理できる

民間の個人情報取扱事業者について、次の5区分すべてにチェックがつくことを、「要配慮個人情報を実名で入力してよい前提環境」の必要条件の整理とします（合格判定や十分条件ではありません。自治体・行政機関等は個人情報保護法の第5章のため別途整理が必要。本資料第3章の補足）。推奨水準による整理で法的な保証ではなく、運用開始前に専門家へ確認してください。

A　本人・目的・契約（法令上の根拠が中心）

- ☐ 利用目的にAI利用を含めて特定し、通知・公表した（法17・21条）。取得済みの記録は、取得時の利用目的の範囲内か確認し、範囲外なら本人の同意等を得た（法18条）
- ☐ 要配慮個人情報の取得に本人の同意を得て記録した（判断能力が十分でない方は法定代理人の同意）（法20条2項）[3]
- ☐ 委託先と、扱いの範囲・目的外利用の禁止・再委託・事故時の連絡を契約で定め、監督の記録を残した（法25条）
- ☐ 入力が学習等に使われないことを、契約・設定で確認した[23]
- ☐ 国外処理は外国名等を示して同意を得た。提供先が「外国にある第三者」に当たるか、または提供に当たらない整理を契約等で確認した。国内処理だけを根拠にしない（法28条）[15]

B　技術・環境（Tier C）

- ☐ データの保存とAI処理が日本国内に閉じる構成にした。Bedrockは使うモデルごとに日本プロファイルを確認した[17][30]
- ☐ Gemini Enterpriseを使う場合、日本非対応のモデル・機能を有効化するとグローバルへ送信される設定を、管理者設定で無効にした[17]
- ☐ キーレス認証、アクセス制御、監査ログを整えた
- ☐ 提供事業者の設置場所と国外法の適用可能性を確認した[24]
- ☐ ISMAPの登録範囲を、使うサービスごとに確認した（目安）[5]

C　運用・体制

- ☐ 組織的・人的・物理的・技術的な安全管理措置を規程にし、実際に運用されていることを点検・教育の記録で確認した（法23条）
- ☐ 3省2ガイドライン相当の組織的措置（第7.0版・第2.0版を参考）を整えた
- ☐ 個人アカウント・無料版・未契約ツールの業務利用を禁止し、入力前の仕分けルール（匿名化できるものは匿名化）を定めた
- ☐ 漏えい等が起きたときの、PPCへの報告と本人への通知の手順を定めた（法26条）

D　決めて記録する　／　E　見直しの体制

- ☐ 安全側の方針（国外処理は同意を前提にする、国内完結を標準にする）を意思決定者が決め、記録した
- ☐ 法務・個人情報保護の専門家に確認し、結果を記録した
- ☐ 見直しの契機と担当者を決め、年1回の再確認日を設定した

見直す契機：PPCが生成AIの新しい考え方を示したとき、令和8年改正法の政令・施行日が決まったとき、基盤・契約相手・主要なモデルを変えるとき、事故が起きたとき。

出典一覧

すべて公式ドキュメント・公式ポータルで直接確認

本文中の番号 [n] に対応します。いずれも2026年10月12日時点で内容を直接確認しています。

法令・個人情報保護

1. 個人情報保護法ガイドライン（外国にある第三者への提供編）｜個人情報保護委員会 — ppc.go.jp/personalinfo/legal/guidelines_offshore

2. 個人情報の保護に関する法律第28条に基づくEU及び英国の指定の見直しに関する報告書｜個人情報保護委員会事務局 — ppc.go.jp/files/pdf/20230322_review_report.pdf

3. 個人情報保護法ガイドライン（通則編）｜個人情報保護委員会 — ppc.go.jp/personalinfo/legal/guidelines_tsusoku

ISMAP

4. ISMAPポータル公式KB0010826（IaaS/PaaS上のSaaSは登録済みIaaS/PaaSと同等とみなせないとの記載） — ismap.go.jp（KB0010826）

5. ISMAPクラウドサービスリスト｜ISMAPポータル公式 — ismap.go.jp/csm?id=cloud_service_list

6. ISMAPポータル公式KB0011070（生成AIサービスに関する留意点について） — ismap.go.jp（KB0011070）

7. Gemini Enterprise・NotebookLM Enterprise の ISMAP登録を完了｜Google Cloud公式ブログ — cloud.google.com/blog/ja/...ismap-registration

31. ISMAP概要（制度案内）｜ISMAPポータル公式 — ismap.go.jp（KB0010005）

クラウド料金・データ所在地

8. Amazon Bedrock は ISMAP の言明対象であることについての考え方｜AWS公式ブログ — aws.amazon.com/jp/blogs/news/amazon-bedrock-ismap

9. Gemini 3.5 Flash／3.8 Flash モデルページ｜Google Cloud公式 — .../3-5-flash ／ .../3-8-flash

10. プロビジョンド スループットを購入する｜Google Cloud公式 — docs.cloud.google.com/.../purchase-provisioned-throughput

11. Agent Platform の料金｜Google Cloud公式 — cloud.google.com/.../generative-ai/pricing

12. Gemini Enterprise app FAQ（30日間無料トライアル）｜Google Cloud公式 — cloud.google.com/gemini-enterprise/faq

13. Gemini API 利用規約｜Google AI for Developers公式 — ai.google.dev/gemini-api/terms

14. Google Workspace「生成AIに関する情報」開示書（Google LLC提出、ISMAPポータル） — ismap.go.jp（開示書PDF）

32. sarashina2.2-3b-instruct-v0.1（モデルカード・MITライセンス）｜SB Intuitions（Hugging Face） — huggingface.co/sbintuitions/sarashina2.2-3b-instruct-v0.1

追補：法令・ガイドライン／日本ロケーション・医療情報

前頁からの続きです。番号は前頁と通しで、2026年10月12日に追加・確認した公式情報を収めています。

法令・個人情報保護委員会（追補）

27. 個人情報の保護に関する法律（平成15年法律第57号）｜e-Gov法令検索 — laws.e-gov.go.jp/law/415AC0000000057

15. 個人情報保護法 Q&A（Q7-53・Q10-25・Q12-3・Q12-4）｜個人情報保護委員会 — ppc.go.jp/personalinfo/faq/APPI_QA

16. 令和８年 改正個人情報保護法について（令和8年7月17日公布）｜個人情報保護委員会 — ppc.go.jp/personalinfo/legal/r8kaiseihogohou

23. 生成AIサービスの利用に関する注意喚起等（令和5年6月2日）｜個人情報保護委員会 — ppc.go.jp/files/pdf/230602_alert_generative_AI_service.pdf

28. 医療・介護関係事業者における個人情報の適切な取扱いのためのガイダンス｜個人情報保護委員会（ガイドライン一覧） — ppc.go.jp/personalinfo/legal/guidelines

29. 行政機関等に係るガイドライン等｜個人情報保護委員会 — ppc.go.jp/personalinfo/legal

医療情報・行政機関向けガイドライン

24. 医療情報システムの安全管理に関するガイドライン 第7.0版（令和8年6月）｜厚生労働省 — mhlw.go.jp/stf/shingi/0000516275_00006.html

25. 医療情報を取り扱う情報システム・サービスの提供事業者における安全管理ガイドライン 第2.0版（令和7年3月）｜経済産業省 — meti.go.jp/…/teikyoujigyousyagl.html

26. 行政の進化と革新のための生成AIの調達・利活用に係るガイドライン 第2.0版（令和8年6月12日）｜デジタル庁 — digital.go.jp/en/news/decb64eb-…

GOOGLE（日本ロケーション・提供終了日）

17. Data residency for Gemini Enterprise Standard and Plus（日本ロケーション）／リリースノート 2026-07-06｜Google Cloud — …/enterprise/docs/locations ／ …/release-notes

18. Security and safety features - Gemini Enterprise（Business edition）｜Google公式ヘルプ — support.google.com/g/answer/17140632

19. Choose a geographic location for your data（Workspaceのデータリージョン）｜Google Workspace公式 — knowledge.workspace.google.com/…/choose-a-geographic-location…

20. Model versions（Gemini 2.5系の提供終了日）｜Google Cloud公式 — …/models/model-versions

AWS（日本国内推論）

21. Amazon Bedrock 日本国内クロスリージョン推論｜AWS公式ブログ — aws.amazon.com/jp/blogs/news/…japan-cross-region-inference

22. Cross-Region inference（地域限定とグローバルの違い）｜AWS公式ドキュメント — docs.aws.amazon.com/bedrock/…/cross-region-inference.html

30. Amazon Bedrock モデルカード（jp. プロファイルと宛先）｜AWS公式 — Claude Sonnet 4.5 ／ Nova 2 Lite

非公開の社内検証

[†] 日本語OCR精度の比較と要約用軽量モデルのCPU評価（p.14）は、実際の業務文書を用いた社内実機検証に基づく知見です。公開されている一次情報へのリンクはありません。数値の再現性は検証環境に依存します。

本資料は2026年10月12日時点で確認できた公式一次情報に基づく技術的整理です。各社の規約・料金・対応リージョンは頻繁に更新されるため、意思決定の直前には必ず公式ページで再確認してください。法的な最終判断は専門家にご確認ください。特定のベンダー・サービスの宣伝を意図したものではありません。